

INSIDER THREAT DATA PROTECTION LAB

USB EXFILTRATION PREVENTION, DATA DISCOVERY, PURVIEW & RIGHTS MANAGEMENT

Report completo dei due esercizi di laboratorio svolti nello scenario fittizio Oscorp, con test, risultati, evidenze e valutazione GRC dei controlli implementati.

Documento	Report – Insider Threat & Data Protection Lab
Scenario	Oscorp Research / Microsoft Security Lab
Focus	USB exfiltration prevention, data discovery, Microsoft Purview, SharePoint, Rights Management
Risultato	Controlli validati con evidenze tecniche
Versione	1.0

INDICE DEI CONTENUTI

1. Obiettivo del laboratorio	3
2. Esercizio 1 — Blocco USB e prevenzione dell'esfiltrazione	3
3. Esercizio 2 — Insider Threat, Data Discovery e protezione dati	4
4. Evidenze tecniche	6
5. Valutazione GRC	7
6. Matrice sintetica dei controlli	8
7. Conclusione e disclaimer	8

REPORT – INSIDER THREAT & DATA PROTECTION LAB

1. Obiettivo del laboratorio

L'obiettivo del laboratorio è stato implementare e validare controlli tecnici per ridurre il rischio di Insider Threat e Data Exfiltration in un ambiente Microsoft.

Lo scenario utilizza un'organizzazione fittizia, Oscorp, che gestisce informazioni sensibili relative a ricerca farmaceutica.

Il laboratorio è stato suddiviso in due esercizi principali:

- Protezione contro l'esfiltrazione tramite dispositivi USB.
- Protezione dei dati sensibili tramite Data Discovery, **SharePoint**, **Microsoft Purview** e **Rights Management**.

2. Esercizio 1 – Blocco USB e prevenzione dell'esfiltrazione

Rischio

Un dipendente potrebbe copiare dati aziendali sensibili su una chiavetta USB o su un altro dispositivo rimovibile.

Controllo implementato

È stata configurata una Group Policy Windows:

```
Removable Disks: Deny write access
```

La policy impedisce:

- copia di nuovi file verso USB;
- modifica di file presenti sul dispositivo;
- sovrascrittura di file esistenti;
- salvataggio diretto di documenti su supporti rimovibili.

Dopo la configurazione è stato eseguito:

```
gpupdate /force
```

Test

Prima dell'applicazione della policy, il file Oscorp_Drug_Formula.txt poteva essere copiato normalmente sulla chiavetta USB.

Dopo l'applicazione del controllo, il tentativo di copia e sovrascrittura è stato bloccato.

Risultato

PASS — Il controllo ha impedito la scrittura e la sovrascrittura su supporti USB, riducendo il rischio di esfiltrazione tramite dispositivi rimovibili.

3. Esercizio 2 – Insider Threat, Data Discovery e protezione dei dati

Data Discovery su SQL Server

È stato installato Microsoft SQL Server e creato il database OscorpResearch. All'interno del database è stata creata la tabella dbo.DrugFormula contenente dati di test con differenti classificazioni.

Per individuare i record sensibili è stata utilizzata la query:

```
SELECT *  
FROM dbo.DrugFormula  
WHERE Classification = 'Highly Sensitive';
```

È stata inoltre eseguita attività di schema discovery tramite INFORMATION_SCHEMA per identificare tabelle, colonne e tipi di dati.

PASS — I dati sensibili presenti nel database sono stati correttamente individuati.

SharePoint Data Discovery

È stato creato il sito SharePoint Oscorp Research. Sono stati inseriti documenti di test, tra cui:

- Drug_Formula_GoblinX.docx
- Clinical_Research_Regen.docx
- General_Research_Notes.docx

I primi due documenti rappresentano informazioni altamente sensibili, mentre il terzo rappresenta contenuto interno ordinario.

Classificazione con Microsoft Purview

In Microsoft Purview è stata creata la sensitivity label Highly Sensitive. La label è stata pubblicata tramite una policy dedicata ed è stata utilizzata per classificare e proteggere i documenti contenenti informazioni sensibili.

Controllo accessi

È stato creato il gruppo Oscorp Drug Research Team. Solo gli utenti autorizzati alla ricerca sono stati inclusi nel gruppo.

È stato inoltre creato un secondo account, oscorp.employee2, utilizzato per simulare un dipendente interno non autorizzato.

La label Highly Sensitive è stata configurata con:

- access control;
- autorizzazioni assegnate al gruppo **Oscorp Drug Research Team**;
- permesso Co-Author;
- accesso offline disabilitato;
- nessuna scadenza dell'accesso.

Test di accesso non autorizzato

È stato creato e protetto il documento Drug_formula_protected.docx.

L'utente autorizzato appartenente al gruppo Oscorp Drug Research Team ha potuto aprire il documento. L'utente oscorp.employee2, non appartenente al gruppo autorizzato, ha tentato di aprire lo stesso file.

Il sistema ha restituito:

Sorry, you don't have permission to open this document.

Il documento risultava protetto tramite Rights Management / Microsoft Information Protection.

PASS — Il dipendente interno non autorizzato non è riuscito ad accedere al documento sensibile.

Data Loss Prevention

È stata inoltre predisposta una policy Microsoft Purview DLP applicata all'ambiente SharePoint Oscorp Research.

L'obiettivo della policy è:

- individuare contenuti classificati come **Highly Sensitive**;
- limitare la condivisione non autorizzata;
- prevenire l'esfiltrazione dei dati;
- supportare monitoraggio e incident reporting.

La protezione tramite Rights Management è stata validata tecnicamente nel laboratorio.

Controlli fisici

Come ulteriore misura di sicurezza sono stati considerati anche controlli fisici, tra cui:

- Clean Desk Policy;
- armadi chiusi a chiave;
- restrizioni sulla stampa;
- distruzione sicura dei documenti;
- limitazioni alla fotografia di documenti riservati.

4. Evidenze tecniche

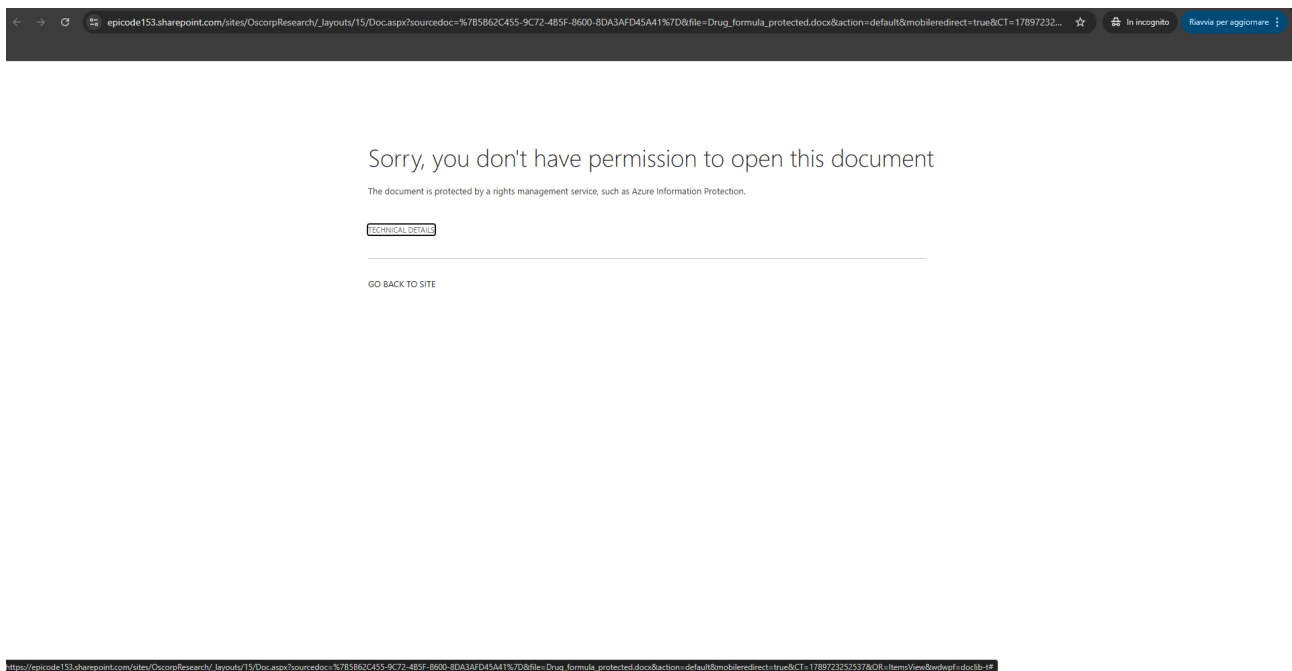


Figura 1 — Evidenza del blocco di accesso al documento protetto tramite Rights Management / Microsoft Information Protection.

☐ Rimuovi le impostazioni di controllo di accesso se già applicate agli elementi

☒ Configura le impostazioni di controllo di accesso

- ① Attivare la creazione condivisa per le app desktop di Office in modo che più utenti possano modificare contemporaneamente i documenti etichettati a cui sono applicate le impostazioni di controllo di accesso. [Scopri di più su questa impostazione](#)

Vai all'impostazione di creazione condivisa

Assegnare le autorizzazioni ora o consentire agli utenti di decidere?

Assegnare ora le autorizzazioni

Le impostazioni scelte verranno applicate automaticamente quando l'etichetta viene applicata alle e-mail e ai file di Office.

L'accesso utente al contenuto scade ①

Mai

Consentire accesso offline ①

Mai

Assegna le autorizzazioni a utenti e gruppi specifici * ①

[Assegna autorizzazioni](#)

1 elemento

Utenti e gruppi	Autorizzazioni	Modifica	Elimina
OscorpDrugResearchTeam@Epicode153.onmicrosoft.com	Co-Author		

Indietro

Avanti

Figura 2 — Configurazione della sensitivity label con controllo accessi, gruppo autorizzato e permesso Co-Author.

Nome del sito ↑ ▾	URL ▾	Teams ▾	Siti del canale ▾	Spazio di archivia... ▾	Amministratore princi... ▾	Hub ▾	Modello ▾
All Company	.../sites/allcompany	-	-	0.00	Proprietari del gruppo	-	Sito del team
Epicode	.../sites/Epicode	👤	-	0.00	Proprietari del gruppo	-	Sito del team
Oscorp Drug Research Team	.../sites/OscorpDrugResearchTeam	👤	-	0.00	Proprietari del gruppo	-	Sito del team
Oscorp Research	.../sites/OscorpResearch	-	-	0.00	Proprietari del gruppo	-	Sito del team
Sito di comunicazione	https://epicode153.sharepoint.com	-	-	0.00	Global Administrator	-	Sito di comunicazione

Figura 3 — Evidenza dei siti SharePoint e dello scenario Oscorp Research / Oscorp Drug Research Team.

5. Valutazione GRC

Il laboratorio ha dimostrato l'applicazione pratica dei seguenti principi:

- **Least Privilege**
- **Need-to-Know**
- **Defense in Depth**
- **Data Classification**
- **Access Control**
- **Data Loss Prevention**
- **Evidence-Based Control Validation**

La logica complessiva del controllo è stata:

Rischio → Data Discovery → Classificazione → Controllo Accessi → Protezione → Test → Evidenza

6. Matrice sintetica dei controlli

Rischio	Controllo	Tipo	Risultato
Esfiltrazione tramite USB	Blocco scrittura/sovrascrittura	Preventivo	PASS
Dati sensibili non identificati	SQL Data Discovery	Detective	PASS
Documenti sensibili non classificati	Purview Sensitivity Label	Preventivo	PASS
Accesso interno non autorizzato	Rights Management	Preventivo	PASS
Permessi eccessivi	Microsoft 365 Group	Preventivo	PASS
Condivisione non autorizzata	Purview DLP	Preventivo / Detective	Predisposto
Rischio documenti cartacei	Controlli fisici	Preventivo	Raccomandato

7. Conclusione e disclaimer

Il laboratorio ha dimostrato un approccio multilivello alla protezione dei dati sensibili contro minacce interne.

Nel primo esercizio è stata validata la prevenzione dell'esfiltrazione tramite USB, bloccando operazioni di scrittura e sovrascrittura.

Nel secondo esercizio sono stati individuati dati sensibili su SQL Server e SharePoint, classificati tramite Microsoft Purview e protetti tramite controlli di accesso e Rights Management.

Il test finale ha dimostrato che un dipendente interno autenticato ma non autorizzato non era in grado di aprire il documento protetto. Questo conferma l'efficacia dei principi di Least Privilege, Need-to-Know e Defense in Depth.

Disclaimer

Tutti i nomi, utenti, formule e dati utilizzati nel laboratorio sono fittizi e creati esclusivamente per finalità accademiche e formative.